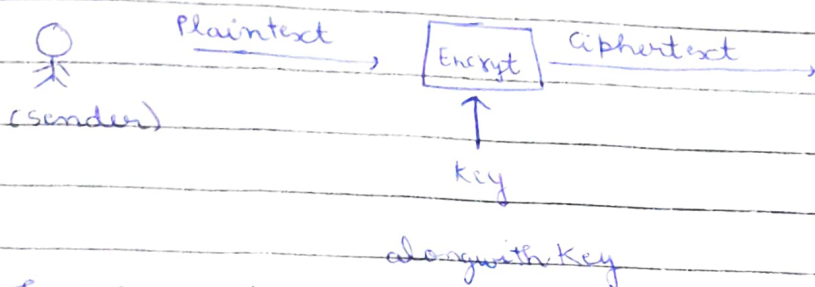
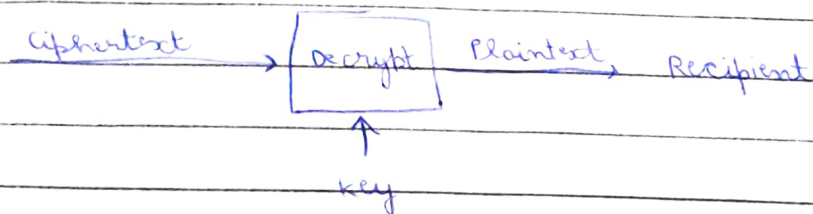


CRYPTOGRAPHY BASICS:

Cryptography is a technique of locking data with math. It makes sure that even if someone steals the data they can't understand it.



The plaintext is passed through an algorithm named as "cipher" which has an encryption function which converts plaintext to ciphertext or vice versa.



then the ciphertext is passed along with a key to a decrypt function which would give us Plaintext again.

- **Cipher**: Is the algorithm to convert plaintext to ciphertext and back again. It is usually developed by a mathematician.

Key: IS a string of bits the cipher uses to encrypt or decrypt data.

- **Caesar Cipher**: It is one of the simplest historical ciphers. The idea is to shift each letter by a certain number to encrypt the message.

Example:

X	Y	Z	A	B	C
↓	↓	↓	↓	↓	↓
A	B	C	D	E	F

Assume key : 3 (Assume right shift)

• Types of Encryption:

a) Symmetric encryption: Also known as symmetric cryptography. It uses the same key for encryption and as well as decryption. It is also called private key cryptography.

Example of symmetric encryption: DES, 3DES, AES

b) Asymmetric encryption: It uses a pair of keys, one to encrypt and other to decrypt. It uses the public key to encrypt data.

NOTE: In Asymmetric encryption, the problem of sharing a key via a very secure network is solved which was in symmetric encryption. How?

In SE: I put the message → I lock it using key → I send the ~~the~~ message. But the main problem was of sharing key if the key leaked, my message can be decrypted.

In ASE: I share the public key to sender → Sender put message and lock it using public key → Now he send the message → The receiver can decrypt it using ~~the private key of the~~ that public's key private key.

So here sharing a key is not done. So secure. Many messages can be encrypted or anyone can encrypt the message using public key. But it can be decrypted only using private key.

Examples of Asymmetric encryption: RSA, Diffie-Hellman, Elliptic Curve Cryptography (ECC).

PUBLIC KEY CRYPTOGRAPHY BASICS :

- When you are talking to a person or suppose your business partner online you need to be sure of the following:

a) Authentication: You need to be sure you communicate with the right person, not someone else pretending.

b) Authenticity: You can verify that the information comes from the claimed source.

c) Integrity: You must be sure no one changes the data you exchange.

d) Confidentiality: You want to prevent any third party to see or listen your conversation.

Private Key cryptography mainly protects: Confidentiality
 Public " " " " : Integrity, Authentication, Authenticity

- RSA: It is asymmetric encryption cipher or algorithm that enables secure data transmission over insecure channels.

RSA is based on the mathematically difficult problem of factoring a large number.

- Diffie-Hellman key exchange:
Key exchange aims to establish a shared secret between two parties. It is a method that allows two parties to establish a shared secret over an insecure channel without requiring a pre-existing shared secret and without an observer being able to get this key.

NOTE: It does not encrypt/decrypt a data it only creates a shared secret key. It solves the major problem of securely sharing a secret key over an insecure network.

- SSH-keygen is the program usually used to generate key pairs. It supports various algorithms:
 - a) DSA (digital signature algorithm)
 - b) ECDSA
 - c) ECDSA-SK
 - d) Ed25519
 - e) Ed25519-SK

- We can login to a remote server using ssh in two ways:
 - 1 = Username + Password
 - 2 = SSH key authentication

Whenever you try to login using SSH firstly ssh tries to authenticate using a) SSH keys; if this failed then it will ask for password.

How does SSH keys work?

Step 1 = Generate SSH keys on your machine.

Step 2: Copy public key to the server. Command: `ssh-copy-id username@server-ip`

Step 3: Now whenever I try to login using SSH keys. It will first ask for key's passphrase then it will check if the private key matches the public key I have saved in the server. If, yes I am logged in.

NOTE: If the remote machine server and my machine are having lots of public and private keys respectively then it will check the key one by one if a single ^{private} key matches the public key you will be logged in.

- **Digital signatures:** They help in proving the authenticity of file means who created or modified it. Using asymmetric cryptography we produce a digital signature using our private key, which can be verified only by our's public key.

Suppose I encrypt a message using my private key. Now anyone can decrypt it using my public key. But it's a digital signature because it gives authenticity message & come from me.

Sender : Message + Digital Signature
 ↓
 encrypted (H1 with private key)

H1: Hash of original msg

Receiver: Decrypts Digital Signature gets H1.
 Generate Hash of the same msg received H2.

If $H1 = H2$ message verified

- Certificate: Certificates are an essential application of public key cryptography. They are used to ^{tell} ~~verify~~ the browser that the webserver you are talking is real because certificates contain a CA's (certificate authority) digital signature, domain name, validity period etc.

- PGP stands for pretty good privacy. It is a software that implements encryption for encrypting files, performing digital signing, and more.

GPG is an open source implementation of the openPGP standard. GPG is used to protect the confidentiality of email messages. It can also be used to sign an email and confirm its integrity.

Command for creating ~~create~~ key pairs for GPG is:

```
gpg --full-gen-key
```

~~How to~~ How to decrypt messages?

```
gpg --decrypt filename
```

HASHING BASICS:

If we want to know that the file we downloaded from the internet is identical to the original file or you want to check whether the file we copied from a USB drive is identical to the file you want to download.

It can be done by hash values.

Hash values is a fixed ~~string~~ size string or characters. They are calculated by hash functions.

Encryption can be reversed using key but hashing cannot be reversed back to original text.

Page No.	
Date:	

- Hash function: It takes some input data of any size and creates a summary or digest of that digest.

Ex: SHA1, MD5, SHA-256.

How to create hash value of a file using a hash function?

`sha1sum
filename`

`md5sum *.txt`: create hash values for all the files in a current directory ending with txt.

NOTE: Each time we create a hash value using the same hash function for same file they will be same. But if the hash function is different ~~for~~ for the same file hash value will be different.

- When you login in a site or a computer most of them saves your password in hash values so whenever you login using your password it converts it into hash value and compare it with saved hash value.
- ~~Hash collision~~ Hash collision: As the number of outputs for a hash function is limited and the number of inputs are unlimited, so hash collision is when two different inputs give same output. Hash functions are designed to avoid collisions as best as possible.
- Salt: A salt is a unique set of number or characters that are unique for each user and they are added to the end or start of a user's password. So now if two users are having the same password also their hash value will differ. Many secure hashing functions ~~also~~ automatically add salt.

MS windows passwords are hashed using NTLM, a variant of MD4. The hashed passwords are stored in the SAM (Security accounts manager). Tools like mimikatz exist to circumvent MS windows security.

Page No.	
Date:	

* In Linux passwords are stored using hashing in shadow file. The password has 9 fields separated by colons: . There are 9 field.

The second field has the format \$prefix\$options\$salt\$hash.

• Hash cat: It is a password recovery / cracking tool

file containing hash you want to crack

Basic usage structure: hashcat -m [hash-type] -a [attack-mode] hash.txt

wordlist.txt → is the security word list you want to use in your attack

-m → hash type

-a → Attack mode

Hash	Mode	Mode	Meaning
MD5	0	0	Dictionary attack
SHA1	100	3	Brute force
SHA256	1400	1	Combination attack
bcrypt	3200	617	Hybrid attack

• Dictionary attack uses wordlist

• Combinational attack uses 2 wordlist combines words from two wordlist

• Brute force attack uses a pattern like 6 digit number, 8 digit character and test all possible

• Hybrid attack uses

NOTE: Crackstation and hashes.com are also online password cracking they also have a database which has already hashed password to original plaintext password mapping. But in hash we have to provide hash-type in input but in both of these they also ~~output~~ output the hash-type with password.